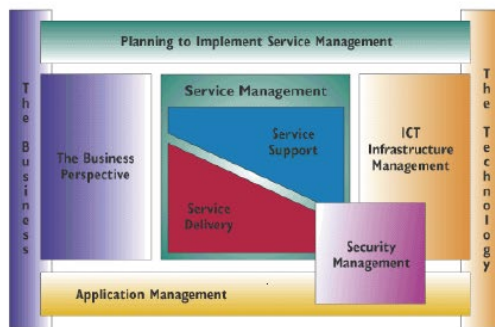


Módulo 5: Instrumentos para la Gestión de la Seguridad

- Necesidad de buenas prácticas en TIs
 - Buenas Prácticas: Adecuada GESTIÓN de los servicios de TIs
 - Evolución: eje centrado en Hardware / Software / Servicios
 - ITIL: Estándar “de facto” en buenas prácticas de provisión de servicios de TIs
 - Origen: “fracaso” proyecto Taurus (años 80) – recopilación buenas prácticas UK
 - Biblioteca: 50 libros / 7 libros (V2) / 5 libros (V3) / ? (V4)
 - ITIL V2: ALINEAR la tecnología con el Negocio
 - ITIL V3: INTEGRAR la tecnología en el Negocio (2008 / ITIL V2011)
 - ITIL V4: Modelo operativo basado en Industria 4.0 (2019...)



ITIL v2 Publication Framework



ITIL v3 Service Lifecycle

Módulo 5: Instrumentos para la Gestión de la Seguridad

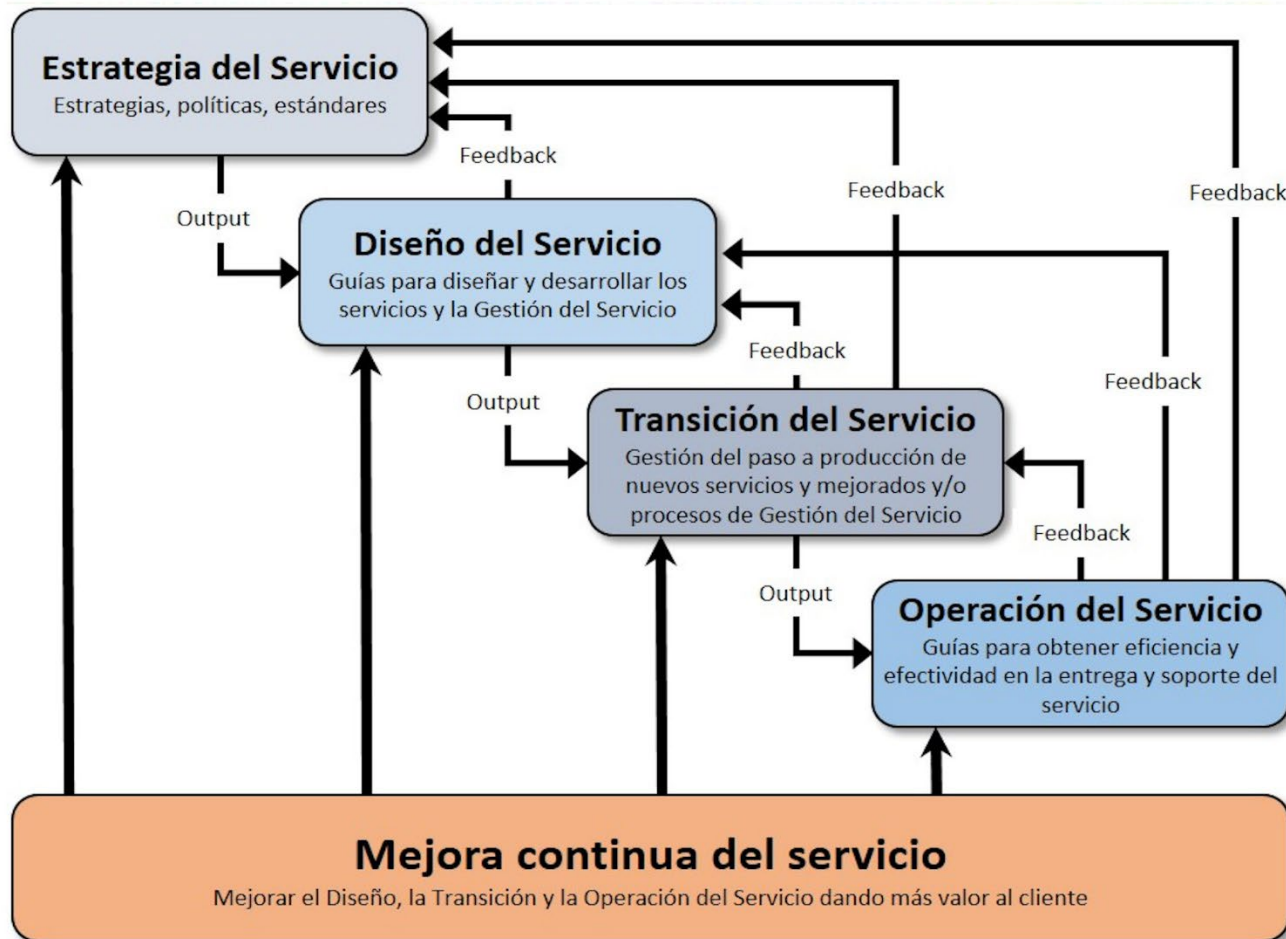
- Definiciones
 - **Buena práctica:** un enfoque o método que ha demostrado su validez y eficacia en la práctica.
 - **Servicio:** es un medio para entregar valor al cliente, facilitando los resultados que los clientes quieren conseguir sin asumir costes o riesgos específicos.
 - **Valor:** desde el punto de vista del cliente supone la conjunción de dos componentes fundamentales: funcionalidad (lo que recibe el cliente) y garantía (la forma en cómo se proporciona)
 - **Gestión de Servicio:** es un conjunto de capacidades organizativas especializadas cuyo fin es generar valor para los clientes en forma de servicios.
 - **Función:** subdivisión de una organización (unidad organizativa) especializada en realizar un trabajo específico y que tiene la responsabilidad de obtener resultados concretos.
 - **Proceso:** es un conjunto estructurado de actividades diseñado para cumplir con un objetivo concreto.

Módulo 5: Instrumentos para la Gestión de la Seguridad

- **La visión de ITIL v3**
 - Buena práctica: enfoque o método que ha demostrado su validez y eficacia
 - Servicio: medio para entregar valor al cliente
 - Proceso: conjunto estructurado de actividades diseñado para cumplir con un objetivo concreto
 - A diferencia de ITIL v2 basado en un enfoque modular, ITIL v3 se orienta a un enfoque estratégico basado en el Ciclo de Vida de los Servicios
 - El Ciclo de Vida del Servicio
 - Estrategia del Servicio
 - Diseño del Servicio
 - Transición del Servicio
 - Operación del Servicio
 - Mejora continua

Módulo 5: Instrumentos para la Gestión de la Seguridad

Etapas del ciclo de vida de los servicios en ITIL V3 (2011)



Módulo 5: Instrumentos para la Gestión de la Seguridad

Procesos en ITIL V3 (2011)

Cada fase o etapa posee dos elementos cruciales para entender el modelo del ciclo de vida:

- **Actividades:** relación de las tareas más importantes a realizar para lograr los objetivos en cada fase.
- **Procesos:** conjunto de actividades con un objetivo específico.

Estrategia del Servicio

- Gestión de la Estrategia
- Gestión del Portafolio
- Gestión Financiera
- Gestión de la Demanda
- Gestión de la relación con el negocio

Diseño del Servicio

- Coordinación de Diseño
- Gestión del Catálogo de Servicios
- Gestión de Niveles de Servicio
- Gestión de la Seguridad
- Gestión de la Disponibilidad
- Gestión de la Capacidad
- Gestión de la Continuidad
- Gestión de Suministradores

Transición del Servicio

- Planificación y Soporte
- Gestión de Cambios
- Gestión de Activos y Configuración
- Gestión de Entregas y Despliegues
- Validación y Pruebas
- Evaluación del Cambio
- Gestión del Conocimiento

Operación del Servicio

- Gestión de Eventos
- Gestión de Incidencias
- Gestión de Peticiones
- Gestión de Problemas
- Gestión de Acceso

Mejora continua del servicio

Modelo de 7 pasos:

- Identificar la estrategia: ¿Qué se debería medir?
- Definir qué medir
- Medir: recopilar los datos
- Procesar los datos
- Análisis
- Presentar la información: informes de servicio
- Implementar mejoras

Módulo 5: Instrumentos para la Gestión de la Seguridad

- **ITIL v4 y la Industria 4.0**

Se definen cuatro dimensiones críticas para alcanzar los objetivos de negocio:

1. Organización y personas.
2. Información y tecnología.
3. Socios y proveedores.
4. Flujos de valor y procesos.

Características esenciales:

- **Aproximación holística:** ITIL v4 define cuatro dimensiones para la gestión del servicio que se consideran especialmente críticas para facilitar la creación de valor tanto para los clientes como para los implicados en forma de productos y servicios.
- **Sistema de valor de servicio (SVS):** describe la manera en que todos los componentes y actividades de una organización trabajan juntos para permitir la creación de valor. Su objetivo es que la organización cree valor de forma continua y cooperativa.
- **Cadena de valor del servicio:** modelo operativo que aglutina las actividades clave necesarias para dar respuesta a la demanda y facilitar valor de negocio a través de la creación y gestión de productos y servicios. Aporta una visión más flexible que el ciclo de vida del servicio.
- **Prácticas ITIL:** En lugar de hablar de procesos, en ITIL v4 se utiliza el concepto de práctica, que se define como un grupo de recursos de organización diseñados para realizar el trabajo o cumplir un objetivo.
- **Integración con otras mejoras prácticas:** esta nueva versión aporta la posibilidad de integrarse con otras metodologías, como Agile, DevOps, Lean, Gobierno TI, etc.

Módulo 5: Instrumentos para la Gestión de la Seguridad

- Análisis de Riesgos
 - Terminología básica y definiciones
 - **Activo:** cualquier recurso (hw, sw, personal, metodológico, etc.) necesario para el funcionamiento de un servicio
 - **Vulnerabilidad:** Debilidad del sistema que puede ser activada, de forma accidental o intencionada
 - **Amenaza:** posibilidad de que se produzca una determinada vulnerabilidad con éxito
 - **Impacto:** Daño que se produce sobre un determinado activo
 - **Riesgo:** Probabilidad de que se produzca un impacto, expresado como producto del daño por dicha probabilidad

Riesgo = Daño * Probabilidad de que éste ocurra

En general, $R = \sum (L_i * P_i)$

Módulo 5: Instrumentos para la Gestión de la Seguridad

- Tipos de Riesgos
 - **Riesgos conocidos:** pueden ser identificados y gestionados, adoptando las medidas oportunas
 - **Riesgos desconocidos:** debidos a situaciones imprevistas, que no permiten tomar medidas a priori
- ¿Qué esperamos del Análisis de Riesgos?
 - Identificar los riesgos inherentes a los activos de información, dentro de su contexto de uso
 - Obtener un informe claro, capaz de ser asimilado y asumido por la Dirección
 - Establecer una clasificación de los riesgos que se asumen, en función de su impacto potencial en la organización
 - Aplicar medidas que conduzcan a la mitigación o eliminación completa, si es posible, de los riesgos más significativos
 - Identificar soluciones alternativas, con sus ventajas e inconvenientes

Módulo 5: Instrumentos para la Gestión de la Seguridad

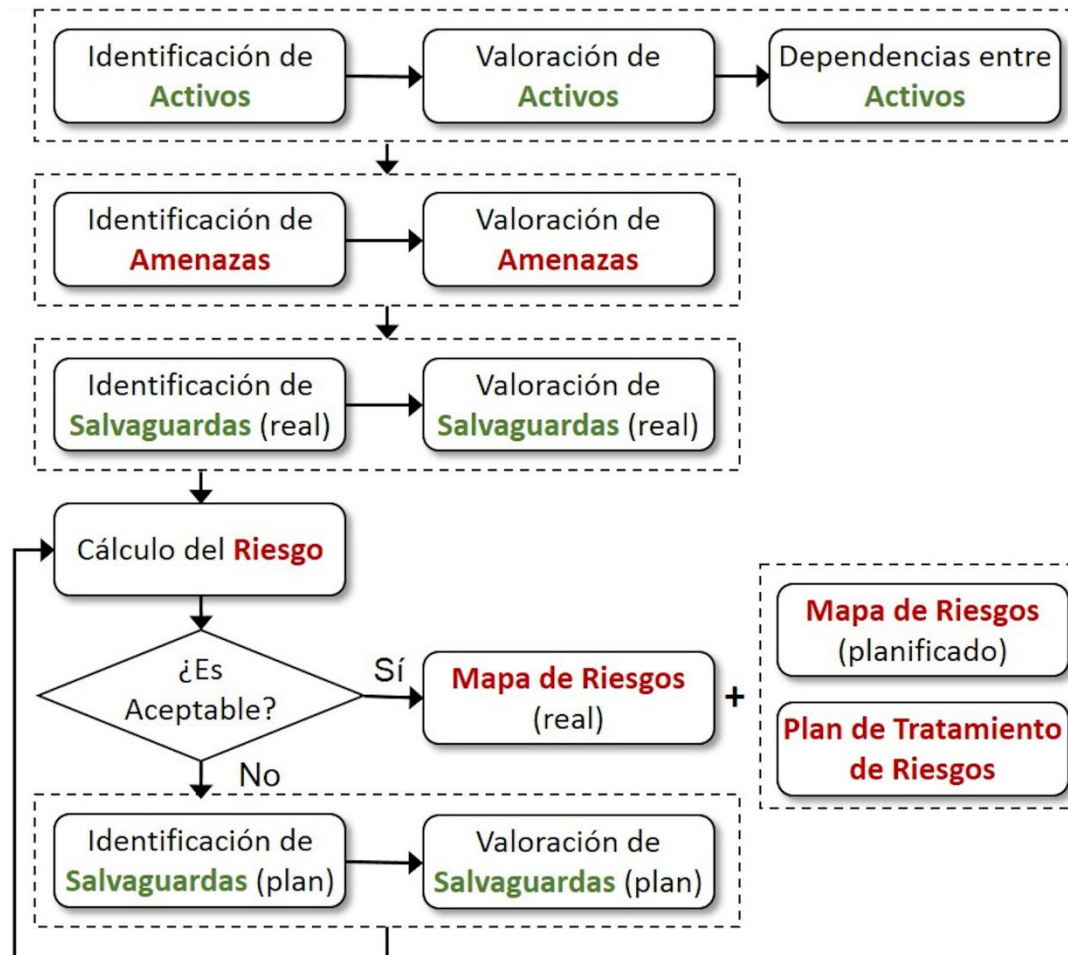
- Metodologías para la implementación de Análisis de Riesgos
 - CRAMM
 - Buenas Prácticas Admon Pública del Reino Unido (1987)
 - Tres Fases (Objetivos, Análisis de Riesgos y Salvaguardas)
 - Utilizado por la OTAN, Gobierno Holandés y multitud de empresas
 - EBIOS
 - Juego de Guías para gestión de Riesgos en TIs (Gob. Francés)
 - Cinco Fases (1.- Análisis del Contexto; 2 y 3.- Requisitos de Seguridad y Amenazas; 4 y 5.- Objetivos de Seguridad)
 - MAGERIT III
 - Se centra en los riesgos propios de los Sistemas de Información para recomendar medidas que controlen su impacto. Primera versión de 1997. Actualmente se estructura en tres Libros:
 - El Método: Secuencia de Acciones y Tareas a Realizar en Gestión de Riesgos
 - Catálogo de Elementos: Describe Activos, Amenazas y Salvaguardas
 - Guías Técnicas: Referencia de técnicas en proyectos de AR
 - ISO/IEC 27005
 - Se basa en modelo PDCA (Plan Do Check Act) y plantea un modelo genérico de gestión de Riesgos
 - Norma UNE 71504 – Metodología de análisis y gestión de riesgos para los sistemas de información.

Módulo 5: Instrumentos para la Gestión de la Seguridad

- Desarrollo de un Análisis de Riesgos
 - Fase I: Gestión de activos. Identificación, valoración y análisis de dependencias
 - Valoración: impacto en cada una de las dimensiones de seguridad por el hecho de que el activo sea dañado
 - Valor acumulado (b) = valor (b) + valor (a) * dependencia
 - Impacto acumulado (a) = impacto (a) + impacto (b) * dependencia
 - Fase II: Detección de amenazas. Identificación y valoración
 - Se clasifican las amenazas de cada activo por dimensión
 - Se estima la vulnerabilidad sobre dos vertientes:
 - Degradación: se estima porcentaje de afectación
 - Frecuencia: estimada (diaria, semanal, mensual, anual, una vez, nunca...)
 - Fase III: Identificación y valoración de salvaguardas
 - Se alinean salvaguardas con amenazas (repositorios en normas ISO 27002, Magerit, Anexos del ENS, etc.)
 - Valoración: grado de eficacia (%)
 - Fase IV: Gestión del riesgo
 - Consiste en identificar y desplegar las medidas que eviten, minimicen y controlen los riesgos identificados de forma que se elimine o reduzca en lo posible el daño
 - Cuatro posibles acciones: **Mitigar, Asumir, Transferir y Eliminar**

Módulo 5: Instrumentos para la Gestión de la Seguridad

Etapas de un análisis de riesgos



Módulo 5: Instrumentos para la Gestión de la Seguridad

- Auditoría de Seguridad (I)
 - Definición
 - Proceso de recogida, agrupación y evaluación de evidencias que determinan si el sistema de información protege el activo empresarial, mantiene la integridad de los datos, ayuda a realizar los fines de la organización y utiliza adecuadamente los recursos
 - No confundir con un **análisis de seguridad** (hacking ético, pruebas de penetración, etc.)
 - Alcance de una auditoría
 - A nivel general:
 - Descripción de sedes y dependencias
 - Estructura orgánica de la organización
 - Actividades y procesos
 - Período de tiempo de la misma
 - Específicamente en auditorías de seguridad de la información:
 - Sistemas afectados y organismos responsables
 - Activos que conforman la infraestructura tecnológica
 - Personal vinculado a dichos activos

Módulo 5: Instrumentos para la Gestión de la Seguridad

- Auditoría de Seguridad (II)
 - Objetivos: VERIFICAR que:
 - La disponibilidad de los sistemas TI está razonablemente asegurada
 - Se han implantado controles para asegurar la integridad, confidencialidad y la autenticación de la información, así como la trazabilidad de las actuaciones
 - Se cumplen las normativas, leyes, reglamentos y buenas prácticas en el ámbito de la seguridad de la información
 - Tipos de auditoría
 - Centradas en la operativa específica de los sistemas TI: auditorías de ciberseguridad, de sistemas SCADA, de aseguramiento de la ciberresiliencia, etc.
 - Como complemento a otras auditorías de cumplimiento normativo
 - Referencia básica
 - CCN-STIC 802 – ENS – Guía de auditoría
 - Resultados
 - Evidencias de los riesgos asociados a los SSII
 - Posibles acciones de mejora

Módulo 5: Instrumentos para la Gestión de la Seguridad

- Auditoría de Seguridad (y III)
- Desarrollo y Ejecución
 - Definición y alcance (ámbito de actuación, nivel de detalle)
 - Configuración del equipo auditor (interno, externo, expertos en temas)
 - Planificación
 - Establecer el plan de auditoría y los conocimientos necesarios del equipo
 - Calendario de revisiones, reuniones y entrevistas
 - Asignar tareas a los miembros y a colaboradores externos en su caso
 - Concretar los criterios de la auditoría
 - Recogida de evidencias
 - Presentación de hallazgos
 - Informe de la auditoría
 - Dictamen final (Conforme, conforme con deficiencias, No conforme)

Módulo 5: Instrumentos para la Gestión de la Seguridad

- Plan Director de Seguridad (I)
 - Definición
 - Un Plan Director define la estrategia en seguridad TIC durante un período de tiempo, detallando acciones a realizar y alineando todas las áreas de la organización con esta estrategia
 - Pretende evitar los problemas más habituales: iniciativas dispares, tomadas de forma aislada, sistemas e infraestructuras heterogéneos, diferentes requisitos de seguridad en la misma organización, etc.
 - Ha de cubrir todos los dominios de seguridad: redes, equipos, seguridad física y lógica, controles de acceso, mantenimiento, adecuación a normativa (LOPDyGDD, LSSI, etc.), política de seguridad, seguridad del personal, continuidad del negocio y control de inventario
 - Norma básica: ISO 27002
 - Objetivos
 - Definir objetivos y criterios básicos en seguridad, establecer el marco normativo y el cumplimiento de la legislación vigente
 - Definir la estructura que gestionará y controlará el cumplimiento de las normas
 - Conocer y planificar los costes e inversiones asociadas a la Seguridad de la Inf
 - Aportar confianza sobre los servicios ofrecidos

Módulo 5: Instrumentos para la Gestión de la Seguridad

- Plan Director de Seguridad (y II)
 - Factores clave para el éxito
 - Compromiso de la dirección
 - Designar un responsable del Plan. Funciones: responsable de la metodología a aplicar, presentar y difundir el trabajo a los actores implicados, revisar documentación, etc.
 - Determinar un marco metodológico
 - Asignar recursos y medios
 - Seguimiento permanente
 - Desarrollo
 - Identificación necesidades de seguridad
 - Análisis y gestión de los riesgos y alineación de la seguridad con la estrategia del negocio, con seguimiento permanente
 - Resultados
 - Nivel de seguridad actual y deseado
 - Necesidades asociadas; proyecto de implantación y hoja de ruta
 - Estudio económico de la inversión requerida; análisis de costes y recursos

Módulo 5: Instrumentos para la Gestión de la Seguridad

- Plan de respuesta ante incidentes (y I)
 - Definición
 - Consiste en documentar detalladamente una relación de tareas y actividades destinadas a dar respuesta a cualquier incidente genérico que afecte a la seguridad de la Información
 - Elementos básicos de un Plan de Respuesta
 - Definición del “Equipo de Respuesta ante Incidentes” o CSIRT
 - Recopilación de procedimientos de actuación
 - Detección y análisis de incidentes
 - Contención del daño y reducción de riesgos
 - Recuperación de servicios
 - Plan de comunicación
 - Valoración de daños y estimación económica
 - Revisión del proceso y actualización de políticas internas

Normas: RDL 12/2018 / ENS / ISO 27000

Módulo 5: Instrumentos para la Gestión de la Seguridad

Plan de Continuidad del Negocio (PCN, SGCN) (I)

Establece la continuidad de las operaciones desde múltiples perspectivas: logística, entorno físico, sistemas de comunicación, infraestructura TI. Seguridad, etc.

- Objetivos generales:
 - Evitar todo tipo de pérdidas
 - Mantener la confianza en la organización
 - Garantizar la comunicación con clientes y proveedores
 - Proteger el medio ambiente
- Objetivos específicos:
 - Mantener el nivel de servicio en umbrales predefinidos
 - Evitar la interrupción de actividades
 - Recuperar la situación inicial ante incidentes de seguridad
 - Definir los tiempos mínimos de recuperación

Módulo 5: Instrumentos para la Gestión de la Seguridad

Plan de Continuidad del Negocio (PCN, SGCN) (y II)

Fases para el desarrollo de un PCN/SGCN

- Definición del alcance (hasta dónde)
- Análisis de la organización (identificar procesos críticos, sus activos y recursos asociados)
 - Reuniones con el personal
 - Análisis del impacto sobre el negocio, determinar:
 - RTO tiempo de recuperación, MTD tiempo máximo tolerable de caída, ROL niveles mínimos de recuperación de servicio, RPO grado de dependencia de la actualidad de datos
 - Análisis de riesgos (obligatorio en tareas previas)
 - Definir los tiempos mínimos de recuperación
- Definir la estrategia de continuidad
- Respuesta (actuaciones, protocolos de recuperación)
- Pruebas, mantenimiento, supervisión y concienciación

Normativa específica: ISO 22301 y documentos INCIBE